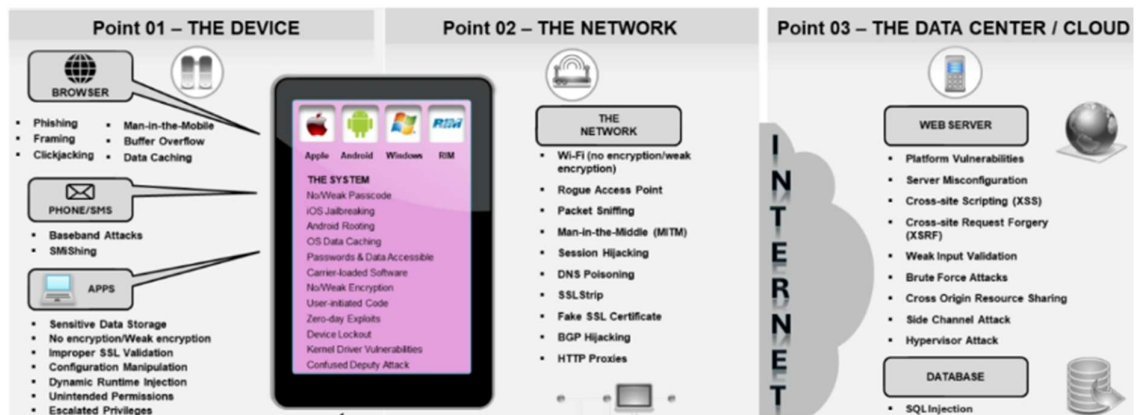


1. Mobile Platform Attack Vectors

- Vulnerable Areas in Mobile Business Environment: Smartphones offer broad Internet and network connectivity via different channels, such as 3G/4G/5G, Bluetooth, Wi-Fi, and wired computer connections these channels during data transmission
- OWASP Top10 mobile risks-2016
 - Improper platform usage
 - Insecure data storage
 - Insecure Communication
 - Insecure authentication
 - Insufficient crypto
 - Insecure authorization
 - Client code quality
 - Code tempering
 - Reverse engineering
 - Extraneous functionality



- Mobile attack vector
 - malware
 - data exfiltration
 - data tampering
 - data loss
- Security Issues Arising from App Stores
 - Insufficient or no vetting of apps leads to malicious and fake apps entering the app marketplace
 - App stores are common target for attackers to distribute malware and malicious apps
- App Sandboxing Issues: Sandboxing helps protect systems and users by limiting the resources the app can access to the mobile platform; however, malicious applications may exploit vulnerabilities and bypass the sandbox
 - ☺ Secure Sandbox Environment
 - ☹ Vulnerable Sandbox Environment
- SMS Phishing Attack (SMiShing): SMS Phishing is the act of trying to acquire personal and financial information by sending SMSs (Instant Messages or IMs) containing deceptive links
- Pairing Mobile Devices on Open Bluetooth and Wi-Fi Connections

- Mobile device pairing on open connections (public Wi-Fi/unencrypted Wi-Fi routers) allows attackers to eavesdrop and intercept data transmission using techniques such as;
 - Bluebugging (gaining control over the device via Bluetooth)
- Sharing data from malicious devices can infect/breach data on the recipient device
- Agent Smith Attack
 - An Agent smith attack is carried out by persuading the victim to install a malicious app designed and published by an attacker
 - The malicious app replaces legitimate apps, such as WhatsApp, SHAREit, and MX Player
 - The attacker produces a huge volume of advertisements on the victim's device through the infected app for financial gain
- Exploiting SS7 Vulnerability
 - Signaling System 7 (SS7) is a communication protocol that allows mobile users to exchange communication through another cellular network
 - SS7 is operated depending on mutual trust between operators without any authentication
 - Attackers can exploit this vulnerability to perform a man-in-the-middle attack, impeding the texts and calls between communicating devices
- Simjacker: SIM Card attack, a vulnerability associated with a SIM card's S@T browser, a pre-installed software on SIM
- Call Spoofing: Call spoofing is a technique used by attackers to manipulate the caller ID information displayed on the recipient's phone when they receive a call

SpoofCard allows attackers to use a virtual number to make calls and send texts while concealing their personal information, regardless of location
- OTP Hijacking/ Two-Factor Authentication Hijacking: Attackers hijack OTPs and redirect them to their personal devices using different techniques such as social engineering and SMS jacking

AdvPhishing is a social media phishing tool that assists attackers in bypassing two-factor or OTP authentication
- Camera/ Microphone Capture Attack : Camfecting Attack: A camfecting attack is a webcam capturing attack that is performed to gain access to the camera of a target's computer or mobile device

access Trojan (RAT) and compromises it to access the victim's camera and microphone

StormBreaker can access a device's location, webcam, and microphone without explicitly requesting any permissions

2. Hacking Android OS

- Android is a software environment developed by Google for mobile devices. It includes an operating system, middleware, and key applications
- Features View System
 - Application framework enabling the reuse and replacement of components
- Webkit
 - Provides a variety of pre-built UI components

- **Android Device Administration API** ▪ The Device Administration API provides device administration features at the system level
 - This API allows developers to create security-aware applications that are useful in enterprise settings, where IT professionals require strong control over employee devices
- **Android Rooting**
 - Rooting allows Android users to attain privileged control (known as "root access") within Android's subsystem
 - Rooting process involves exploiting security vulnerabilities in the device firmware and copying the SU binary to a location in the current process's PATH (e.g., /system/xbin/su) and granting it executable permissions with the chmod command
 - KingoRoot allows Android rooting via PC by connecting with USB and clicking "ROOT," or without PC by installing the APK and using "One Click Root." Multiple attempts may be needed.
 - One Click Root is an Android rooting software that allows rooting of an Android smartphone and provides access to additional features such as gaining access to more apps, installing apps on SD cards, accessing blocked features, etc
- **Hacking Android Devices**
 - Attackers use the drozer tool to discover various vulnerabilities and attack surfaces on Android devices and apps
 - Factory Reset Protection (FRP) prevents unauthorized access to reset Android devices, but tools like 4ukey and Octoplus FRP can be used to bypass it.
 - Hacking with zANTI and Kali NetHunter:
 - zANTI: Android tool for MAC spoofing, malicious Wi-Fi hotspot creation, and session hijacking.
 - Kali NetHunter: Mobile penetration testing platform offering tools for attacks like HID keyboard emulation and more.
 - Launch DoS Attack using Low Orbit Ion Cannon (LOIC)
 - Hacking with Orbot Proxy: Attackers can use this application to hide their identity while performing attacks or surfing through target web applications.
 - Attackers can use this application to hide their identity while performing attacks or surfing through target web applications.: Android Debug Bridge (ADB) is a command-line tool that allows attackers to communicate with the target Android device
 - Launching Man-in-the-Disk Attack: Attackers perform man-in-the-disk (MITD) attacks when applications do not incorporate proper security measures against usage of the device's external storage
 - This vulnerability leads to the installation of potentially malicious apps to the user's devices, thereby blocking access to legitimate apps
 - Launch spearphone attack: Allow apps to record loudspeaker data without privileges.
 - Exploiting Android Devices Using Metasploit: The Metasploit Framework allows attackers to use custom or in-built exploits and payloads for exploiting the target Android device and obtain sensitive information
 - Analyzing Android Devices: Analyzing Android devices involves examining the system to gather information, understand behavior, or identify vulnerabilities for various purposes
 - Other Techniques for Hacking Android Devices

- Advanced SMS Phishing
 - Attackers use any low-priced USB modem and trick the victim into accepting the malicious settings in the mobile, which results in redirecting all the victim's data to the attacker
- Bypass SSL Pinning
 - Attackers can exploit SSL pinning using techniques such as reverse engineering and hooking
 - Attackers modify the source code of the application to bypass SSL pinning and further perform man-in-the-middle attacks
- Tap 'n Ghost Attack
 - This attack targets NFC technology and RX electrodes used in capacitive touchscreens of mobile devices
 - Tap 'n Ghost is based on two attack techniques: Tag-based Adaptive Ploy (TAP) and Ghost Touch Generator
- Android Malware: Mamont is an Android banking Trojan that masquerades as the Chrome browser application, aiming to deceive users into unwittingly downloading and installing the Trojan
 - Upon installation, the Trojan prompts the user to grant permissions such as sending and receiving phone calls and SMS messages
- Android Hacking Tools
 - AndroRAT provides a full persistent backdoor to the target device as the app starts automatically on device boot up
 - Ghost framework is an Android post-exploitation tool that leverages the Android Debug Bridge (ADB) to gain remote access to Android devices
- Android-based Sniffers: PCAPdroid is an open-source application that allows attackers to track, examine, and block connections made by other applications, simulating a VPN to capture network traffic without requiring root access.
- Securing Android Devices
 - Enable screen lock for your Android phone
 - Use strong passwords and biometrics
 - Kaspersky Antivirus for Android is an Android security app focusing on anti-theft and virus protection for mobile devices and tablets. It is designed to help users find their device if it is lost or stolen.
 - Google's Find My Device helps you easily locate a lost Android device and keeps your information on the missing device safe while you look for it
 - Quixxi App Shield can be used by enterprises and mobile app developers to secure their mobile apps from piracy, revenue loss, intellectual property (IP) theft, loss of user data, hacking, and cracking(Android Vulnerability Scanners)
 - Security analysts perform static analysis on malicious Android APKs to examine the code without executing the app
 - This method helps in identifying harmful features or vulnerabilities in the application, or to compare the suspected APK code against malware signatures to identify known malware variants
 - Sixo Online APK Analyzer allows you to analyze various details about APK files. It can decompile binary XML files and resource

3. Hacking iOS

- iOS is Apple's mobile operating system; it supports Apple devices such as iPhone, iPod touch, iPad, and Apple TV
- The user interface is based on the concept of direct manipulation, with multi-touch gestures
- Jailbreaking iOS
 - Jailbreaking is defined as the process of installing a modified set of kernel patches that allows users to run third-party applications not signed by the OS vendor
 - Jailbreaking provides root access to the operating system and permits downloading of third-party applications, themes, and extensions on iOS devices
 - Jailbreaking removes sandbox restrictions, which enables malicious apps to access restricted mobile resources and information
 - Jailbreaking, like rooting, also comes with many security and other risks to your device, which include the following:
 - Voiding your phone's warranty
 - Poor performance
 - Malware infection
 - "Bricking" the device
 - Types of Jailbreaking
 - Userland Exploit
A userland jailbreak allows user-level access but does not allow iboot-level access
 - iBoot Exploit
An iboot jailbreak allows both user-level access and iboot-level access
 - Bootrom Exploit
A bootrom jailbreak allows both user-level access and iboot-level access
 - Jailbreaking Techniques
 - Untethered Jailbreaking
 - An untethered jailbreak has the property that if the user turns the device off and back on, the device will completely start up, and the kernel will be patched without the help of a computer; in other words, it will be jailbroken after each reboot
 - Semi-tethered Jailbreaking
 - A semi-tethered jailbreak has the property that if the user turns the device off and back on, the device will completely start up and will no longer have a patched kernel, but it will still be usable for normal functions. To use jailbroken addons, the user need to start the device with the help of a jailbreaking tool
 - Tethered Jailbreaking
 - With a tethered jailbreak, if the device starts back up on its own, it will no longer have a patched kernel, and it may get stuck in a partially started state; for it to completely start up with a patched kernel, it must be "re-jailbroken" with a computer (using the "boot tethered" feature of a jailbreaking tool) each time it is turned on
 - Semi-untethered Jailbreaking
 - A semi-untethered jailbreak is similar to a semi-tethered jailbreak. In this type of a jailbreak, when the device reboots, the kernel is not patched, but the kernel can still be patched without using a computer. This is done using an app installed on the de

- Jailbreaking iOS Using Hexxa Plus: Hexxa Plus is a jailbreak repo extractor for the latest iOS, which allows the user to install themes, tweaks, and apps
 - Using Hexxa Plus, the user can install the latest iOS jailbreak apps by extracting repos
- Redensa is a jailbreak solution that comes with iTerminal. It makes the process of installing jailbreak apps and tweaks easier,
- Hacking iOS Devices
 - Hacking using Spyzie: Attackers hack the target device remotely in an invisible mode without even jailbreaking the device
 - iOS Trust jacking: OS Trustjacking is a vulnerability that can be exploited by an attacker to read messages and emails and capture sensitive information from a remote location without the victim's knowledge
 - This vulnerability exploits the "iTunes Wi-Fi Sync" feature, where the victim connects their phone to any trusted computer that is already infected by an attacker
 - SeaShell Framework

SeaShell Framework is an iOS post-exploitation framework that allow attackers to remotely access, control, and extract sensitive information from compromised devices
 - Analyzing and Manipulating iOS Applications
 - **Cycript** allows runtime manipulation of iOS apps, enabling attackers to modify app behavior (e.g., bypass authentication) using Objective-C and JavaScript
 - **Method Swizzling** lets attackers alter method functionality at runtime for tasks like logging or jailbreak detection bypass
 - **Keychain Dumper** extracts sensitive data (e.g., passwords, tokens) from iOS's secure storage.
 - **Objection** is used for runtime analysis, SSL pinning bypass, method hooking, and jailbreak detection evasion.

Analyzing iOS Devices

Analyzing iOS devices allows attackers to understand the system's **architecture**, uncover **vulnerabilities**, and identify **exploitable weaknesses**

Techniques	Descriptions
Accessing the Device Shell	- Install the OpenSSH package in the iOS device and connect both iOS device and the host computer to the same Wi-Fi network - Run the <code>root@<device_ip_address></code> command to access the remote device's shell
Listing installed apps	Use tools such as Frida and run the <code>frida-ps -Uai</code> command to list all the apps currently installed on the device
Network sniffing	- Run the <code>rvictl -s <UDID of the iOS device></code> command in the Terminal to start the device with <code>rvio</code> interface - Start the Wireshark tool and choose the interface as "<code>rvio</code>" - Filter the traffic using capture filters for specific monitoring <code>ip.addr == 192.168.2.4 && http</code>
Obtain open connections	Run the <code>lsiof -i</code> command to obtain a list of open network ports for all active processes on the device
Process exploration	Use tools such as <code>r2frida</code> along with a target app such as <code>iGoat-Swift</code>. After establishing an <code>r2frida</code> session, run the <code>:dm</code> command to retrieve the app's memory maps

- GoldPickaxe Trojan allows attackers to trick victims into scanning their faces including their identification documents(IOS Malware)
 - The attackers ask the victims to install a masked form of MDM profile that allows them remotely configure the target iOS devices by sending profiles and commands

- Elcomsoft Phone Breaker allows attackers to perform logical and over-the-air acquisition of iOS devices, break into encrypted backups, and obtain and analyze backups, synchronized data, and pass(IOS Hacking Tool)
- Securing iOS Devices
 - Enable the Passcode Lock feature on your iPhone. Go to Settings → Face ID & Passcode, and then tap Turn Passcode On
 - Set separate passcodes for applications containing sensitive data
 - Disable Javascript and add-ons from the web browser
 - Always download applications from the Apple App Store
 - Set the Auto-Lock Timeout to enter a passcode after a set time. Go to Settings → General → Auto-Lock
 - Malwarebytes Mobile Security tool filters text messages, blocks intrusive ads, fraudulent calls, phishing sites, and malicious content, and offers a VPN service that encrypts connections(iOS Device Security Tools)
 - Find My iPhone helps locate and protect Apple devices that are lost or stolen
 - It helps locate a missing device on a map, remotely lock it, play a sound, display a message, and remotely erase all data on it(iOS Device Tracking Tools)

4. Mobile Device Management

- Mobile Device Management (MDM):
 - Mobile Device Management (MDM) provides platforms for over-the-air or wired distribution of applications and data and configuration settings for all types of mobile devices, including mobile phones, smartphones, and tablet computers
 - MDM helps in implementing enterprise-wide policies to reduce support costs, business discontinuity, and security risks
 - It helps system administrators to deploy and manage software applications across all enterprise mobile devices to secure, monitor, manage, and support mobile devices
- Mobile Device Management Solutions:

Scalefusion MDM Software provides comprehensive visibility across the network for IT teams and gives control required to secure, manage and monitor any corporate or employee-owned devices
- Bring Your Own Device (BYOD): Bring your own device (BYOD) refers to a policy that allows an employee to bring their personal devices, such as laptops, smartphones, and tablets, to their workplace and use them to access the organization's resources by following the access privileges
- BYOD Risks
 1. Sharing confidential data on unsecured networks
 2. Data leakage and endpoint security issues
 3. Improperly disposing of devices
 4. Support for many different devices
 5. Mixing personal and private data
 6. Lost or stolen devices
 7. Lack of awareness
 8. Ability to bypass organization's network policies

5. Mobile security guidelines

OWASP Top 10 Mobile Risks and Solutions

Risks	Solutions
Improper Credential Usage	- Avoid using hardcoded credentials - Encrypt credentials during transmission
Inadequate Supply Chain Security	- Ensure secure app signing and distribution processes - Use only trusted and validated third-party libraries or components
Insecure Authentication/Authorization Usage	- Avoid weak authentication design patterns - Reinforce server-side authentication
Insufficient Input/Output Validation	- Implement strict input and output validation techniques - Use data integrity checks and follow secure coding practices
Insecure Communication	- Use certificates signed by a trusted CA provider - Ensure that certificates are valid and fail closed

Risks	Solutions
Inadequate Privacy Controls	- Protect access must be protected with proper authentication and authorization - Use static and dynamic security checking tools
Insufficient Binary Protections	- Use code obfuscation and anti-tampering techniques - Use local security checks, backend enforcement, and integrity checks
Security Misconfiguration	- Refrain from using hardcoded default credentials - Disable debugging features in the production version of the app
Insecure Data Storage	- Store sensitive data in secure, restricted-access storage locations - Regularly update and patch all libraries, frameworks, and third-party dependencies
Insufficient Cryptography	- Use strong encryption algorithms having sufficient key length - Use strong hash functions such as SHA-256 or bcrypt

- Avoid auto-upload of files
- Perform security assessment of applications
- Turn off Bluetooth
- Allow only necessary GPS-enabled applications
- Do not connect to open network
- Install applications from trusted sources
- Use strong password
- Use [Mobile Device Management \(MDM\)](#) softwares
- Update operating system often
- Do not allow rooting / jailbreaking
- Encrypt phone storage
- Periodic backup
- Configure mobile device policies

Reverse Engineering Mobile Applications

- Reverse engineering is the process of **analyzing and extracting** the source code of a software or application, and if needed, regenerating it with required modifications
- Reverse engineering is used to **disassemble a mobile application** to analyze its design flaws and fix any bugs that are residing in it

Reverse engineering is used to:

- Read and understand the source code
- Detect underlying vulnerabilities
- Scan for sensitive information embedded in the source code
- Conduct malware analysis
- Regenerate the application after some modifications

Why is reverse engineering effective?

- Initiates security analysis
- Initiates black-box testing on mobiles apps
- Improves static analysis in black-box testing
- Performs resilience assessment
- Performs compliance and auditing

Source Code Analysis Tools Syhunt Mobile

Syhunt Mobile analyzes the source code of mobile applications and performs over 350 vulnerability checks for Java and Android, and 240 vulnerability checks for iOS

Reverse Engineering Tools Apktool

Apktool is used for reverse engineering third-party, closed, binary Android apps. It can decode resources to nearly original form and rebuild them after making some modifications

App Repackaging Detectors Appdome

- Appdome provides defenses against app tampering, reverse engineering, method hooking, and unauthorized repackaging
- The mobile app integrity and checksum validation feature verifies the integrity of the app by creating checksums for its binary data and structure, preventing unauthorized modifications and fake apps

Mobile Protection and Anti-Spyware Tools Avast Antivirus & Security

- Avast Antivirus & Security helps users in scanning and securing their devices against viruses and other malware components, strengthening privacy, and experiencing faster performance
- The tool performs automated scans to detect threats and vulnerabilities, and blocks malicious apps before getting installed
- TotalAV is a comprehensive security tool designed to detect and halt various forms of spyware that aim to snoop on and exploit users' data for financial gain

Mobile Pen Testing Toolkits

ImmuniWeb® MobileSuite

ImmuniWeb® MobileSuite leverages machine learning technology to augment and accelerate manual mobile penetration testing of iOS and Android mobile applications